



Authenticity Is Not Legitimacy: The Rise of Trusted Infrastructure Phishing

A Technical and Strategic Analysis of System Notification Abuse, Identity Infrastructure Exploitation, and the Collapse of Conventional Email Trust

AUTHOR

KBS <admin@dtrh.et>

PUBLISHED

May 26 2026

CLASSIFICATION

Public Research — For Distribution

WORD COUNT

~18,000 words



Published: May 26 2026 | Classification: Threat Intelligence / Security Research

Audience: Security Researchers · CISOs · SOC Analysts · Enterprise IT · Cyber Threat Intelligence

Primary Case Study: [Abnormal AI – System Notification Abuse: How Attackers Force Microsoft to Send Phishing Emails](#) (January 29, 2026)

Abstract

A new and structurally distinct category of phishing has emerged—one that does not forge, spoof, or mimic trusted infrastructure. Instead, it **commands** that infrastructure to act as the attacker's delivery mechanism. This paper analyzes the mechanics, psychology, economics, and strategic implications of what security researchers now call **Trusted Infrastructure Phishing** or **System Notification Abuse**: an attack paradigm in which threat actors manipulate legitimate cloud platform features to force those platforms to send malicious messages on their behalf.

The central case study—discovered by Abnormal AI researchers and published in January 2026—demonstrates how attackers exploited Microsoft Entra ID tenant branding features to inject fraudulent financial alert messages directly into legitimate Microsoft system notifications, sent from

`msonlineservicesteam@microsoftonline.com`, passing all SPF, DKIM, and DMARC authentication checks, containing only legitimate Microsoft URLs, and targeting recipients with a callback phishing payload designed to steal payment credentials or remote access.

Across a corpus of 2,000 unique messages spanning more than 250 abused Microsoft 365 tenants, researchers found a highly industrialized "burn-and-churn" operation: scripted tenant creation, Unicode obfuscation to defeat optical character recognition, regex-evading phone number formatting, and automated account provisioning via the Microsoft Graph PowerShell SDK. This is not an opportunistic experiment. It is a scalable, operationally mature campaign that reveals a deeper structural truth:

The authentication of a message no longer implies the legitimacy of its content.

This paper examines that proposition in exhaustive technical and strategic depth—tracing the attack chain step by step, situating it within the broader "Living off Trusted Sites" (LOTS) threat category, exploring the psychological scaffolding of callback phishing, analyzing why traditional email security architectures are architecturally blind to this class of attack, and forecasting how AI will industrialize these techniques at previously impossible scale.

1. Introduction: When the Authenticator Becomes the Accomplice

There is a foundational assumption embedded in almost every enterprise email security architecture built over the last two decades: that the origin of a message is a reliable proxy for its trustworthiness. This assumption is not naive—it is the logical conclusion of a decade of investment in email authentication standards. SPF tells you which servers are authorized to send on behalf of a domain. DKIM cryptographically signs the message content so receivers can verify it was not tampered with in transit. DMARC ties these together, allowing domain owners to specify what should happen to unauthenticated mail. Between these three protocols, the email security industry constructed something that felt like a chain of custody—a technical handshake between sender and receiver that made forgery detectable and impersonation costly.

That assumption is now structurally broken.

Not because attackers found a cryptographic flaw in DKIM. Not because SPF records can be trivially forged. The assumption broke because the attack model evolved past the point where authentication is relevant. The Microsoft notification abuse campaign documented by Abnormal AI researchers in early 2026 represents the logical extreme of a threat vector that has been quietly maturing for years: instead of impersonating a trusted entity, **attackers now co-opt the trusted entity itself** to do the sending.

The email arrives from `msonlineservicesteam@microsoftonline.com`—a domain operated by Microsoft Corporation. It passes SPF because it originates from Microsoft's own mail infrastructure. It passes DKIM because Microsoft signed it. It passes DMARC because both SPF and DKIM align with Microsoft's domain. It contains no malicious links—only legitimate URLs to Microsoft's Privacy Policy and Legal pages. It contains no malicious attachments. It matches the formatting of genuine Microsoft security notifications so precisely because it is a genuine Microsoft security notification—structurally speaking. The only "malicious" element is the tenant name that Microsoft's template system faithfully injected into the subject line and signature block, because an attacker registered a Microsoft 365 tenant and set its name to a fraudulent cryptocurrency charge alert.

Microsoft did not get hacked. No vulnerability was exploited in the traditional sense. No API was called without authorization. The attacker used Microsoft's own tools, in the manner Microsoft designed them to be used, to generate a message that Microsoft's own infrastructure transmitted, authenticated, and delivered to the victim's inbox—where it almost certainly bypassed allowlist-based filtering because security teams routinely whitelist `msonlineservicesteam@microsoftonline.com` to ensure employees receive legitimate MFA codes.

This is the architecture of the new threat.

This paper traces that architecture in full—technical depth, psychological dimension, economic model, and strategic implication. It then asks the harder question: if authenticity can no longer be trusted, what can be?

2. The Collapse of Traditional Trust Signals

2.1 The Authentication Trilogy: What It Was Built to Do

Email authentication was designed to solve a specific, well-defined problem: unsolicited parties sending messages that falsely claimed to originate from domains they did not control. The three-protocol stack—SPF, DKIM, and DMARC—addressed this reasonably well within its original threat model.

SPF (Sender Policy Framework), defined in RFC 7208, allows domain owners to publish a list of authorized sending IP addresses via DNS TXT records. A receiving mail server can check whether the inbound message arrived from an IP the domain owner authorized. If not, the SPF check fails.

DKIM (DomainKeys Identified Mail), defined in RFC 6376, provides cryptographic message integrity. The sending mail server signs the message with a private key; the receiving server fetches the corresponding public key from DNS and verifies the signature. This proves the message was not altered in transit and that the signing organization controls the domain used in the signature.

DMARC (Domain-based Message Authentication, Reporting & Conformance), defined in RFC 7489, adds policy enforcement and reporting. It requires that at least one of SPF or DKIM "aligns" with the visible From: domain—the domain the user actually sees. A DMARC policy of `p=reject` instructs receiving servers to discard messages that fail alignment.

Together, these protocols largely solved the problem of crude domain spoofing. By 2024, Google and Yahoo's bulk sender requirements had pushed major email platforms toward DMARC enforcement, and adoption rates climbed dramatically. In theory, the era of mass impersonation of major brands via domain spoofing was over.

2.2 The Fundamental Limitation: They Only Authenticate, They Don't Authorize

Here is what the authentication trilogy does not—and cannot—do: verify whether the *content* of an authenticated message is legitimate.

SPF, DKIM, and DMARC validate the *channel*, not the *cargo*. They answer the question "did this message genuinely originate from this infrastructure?" with increasing precision. But they say nothing about whether the content within an authenticated message constitutes a social engineering attack, a fraudulent financial alert, or a prompt to call a vishing line.

This limitation was always latent. It became operationally consequential the moment attackers discovered they could satisfy the authentication requirements of a major platform's infrastructure *by design*, without any

credentials theft or vulnerability exploitation—simply by provisioning that infrastructure for themselves and exploiting features that inject attacker-controlled data into legitimate system templates.

2.3 The "Trusted Sender" Allowlist Problem

The authentication failure is compounded by a defensive practice that turns authentication success into an active vulnerability: the sender allowlist.

Because authentication-passing emails from major infrastructure providers like Microsoft are typically legitimate and operationally critical (think: MFA codes, password reset confirmations, account security alerts), security teams routinely configure their email security platforms to exempt those senders from deeper scrutiny. An email arriving from `msonlineserviceteam@microsoftonline.com` with a passing DMARC verdict is not just trusted implicitly by authentication standards—it is *actively whitelisted* by security operations teams who know employees need to receive these messages reliably.

The attacker's insight was elegant in its brutality: the whitelist is an attack surface. If you can force `msonlineserviceteam@microsoftonline.com` to deliver your payload, you inherit the whitelist's exemptions. The authentication stack becomes a weapon against the organizations it was meant to protect.

2.4 The Scope of Trust Signal Collapse

The Microsoft notification abuse attack is the most technically elegant example of this failure mode, but it is far from the only one. Across the threat landscape, a consistent pattern emerges: **the things enterprises trust most are the things adversaries now target most deliberately.**

- Legitimate OAuth tokens obtained through consent phishing bypass MFA entirely—because they represent authorized access by design.
- Phishing pages hosted on Google Drive, SharePoint, Canva, or Dropbox inherit the domain reputation of those platforms, defeating URL filtering.
- Microsoft Teams messages from external tenants arrive in the trusted Teams interface—even when the external tenant was created minutes ago by a threat actor.
- Push MFA notifications from Microsoft Authenticator are inherently trusted—because the system was designed to approve them.

In each case, the attack leverages *genuine* infrastructure, *genuine* authentication signals, and *genuine* trust relationships—and corrupts the outcome by controlling the content or context flowing through them. The common thread is not a technical vulnerability but an architectural assumption: **that authenticity implies legitimacy.**

That assumption is dead.

3. Anatomy of the Microsoft Notification Abuse Attack

3.1 Campaign Overview

The attack documented by Abnormal AI's threat intelligence team—published January 29, 2026—represents one of the clearest examples yet of what researchers are beginning to call "System Notification Abuse" or, more broadly, "Trusted Infrastructure Phishing." The campaign was not small-scale or experimental. Researchers analyzed 2,000 unique messages spanning over 250 abused Microsoft 365 tenants—evidence of an industrialized operation with deliberate automation and clear economic incentives.

The campaign's objective is financial fraud via callback phishing, also known as Telephone-Oriented Attack Delivery (TOAD). The victim receives a message that appears to be a legitimate Microsoft security notification—complete with real authentication headers, legitimate Microsoft URLs, and the visual formatting of genuine system communications—containing an alarming financial claim and a phone number to call for "support." When they call, they reach a social engineering operator who extracts payment credentials, personal information, or remote desktop access.

3.2 Campaign Characteristics

Several features distinguish this campaign as operationally mature rather than opportunistic:

Scale and automation. 250+ abused tenants producing 2,000+ distinct messages is not manual effort. Researchers identified scripted tenant creation as the likely production mechanism, with Microsoft Graph PowerShell SDK (`New-MgUserAuthenticationMethod`) enabling programmatic batch-configuration of authentication methods across thousands of ephemeral accounts in single operations.

The burn-and-churn model. Rather than maintaining persistent infrastructure that might be detected and taken down, attackers create disposable tenants—typically using free trials or basic subscriptions on `*.onmicrosoft.com` subdomains—launch attack waves, then abandon them. This approach mirrors the operational security discipline observed in ransomware affiliate groups and professional BEC operations.

Layered evasion. The campaign deploys at least three distinct technical evasion mechanisms beyond the core trust exploitation: the subject line hijack, Unicode obfuscation via ogonek substitutions, and regex-defeating phone number formatting. The presence of multiple, orthogonal evasion techniques indicates adversarial knowledge of the detection mechanisms being evaded—likely derived from testing against live security tooling.

Payload consistency. The specific lure—a fraudulent Bitcoin or cryptocurrency purchase allegedly processed through PayPal—is a well-established pretextual trigger in the callback phishing ecosystem, designed to

maximize urgency, financial anxiety, and the impulse to immediately call the "support" number. The specificity of dollar amounts (e.g., "\$498.95") is a deliberate realism-enhancement technique.

3.3 The Core Exploit: Tenant Branding Feature Abuse

The attack's central mechanism is the manipulation of Microsoft Entra ID's **Tenant Branding** configuration. This feature exists for a legitimate purpose: organizations customize their Microsoft 365 tenant with a display name, logo, and branding elements that appear in system communications to their users, creating a consistent organizational identity.

Within the Entra ID portal, under "Tenant Properties," administrators can modify the **Tenant Name** field. Microsoft's notification system templates use this field as a variable—inserting `{Tenant Name}` into the subject lines, headers, and signature blocks of automated system emails. The mechanism was designed with the assumption that the entity controlling the tenant would be a legitimate organization naming it after their business.

The attackers realized that this assumption is not enforced. Nothing in Microsoft's tenant provisioning logic validates that a Tenant Name contains only organizational identifiers. By setting the Tenant Name to a fraudulent financial alert string—specifically documented as: *"Your Bitcoin Purchased of USD 498.95 Completed through PayPal. Reach Support Desk at 802 538 3069 to Cancel or Renew."*—the attacker ensured that Microsoft's own templating engine would inject this text into every system notification generated by that tenant.

The exploit required no vulnerability. No code injection, no API abuse, no unauthorized access. The attacker simply used the Tenant Name field for a purpose it was not designed for but was not technically restricted from.

3.4 Triggering Delivery: The Security Info Registration Flow

Having weaponized the tenant branding, the attacker needed to trigger Microsoft to send a notification to the target. The mechanism chosen was the **Security Info registration portal** at

`mysignins.microsoft.com/security-info`—the legitimate Microsoft interface where users manage their MFA and backup authentication methods.

The attacker's operational steps: 1. Create a user account within the malicious tenant (e.g., `CarlyVargas@Williford316.onmicrosoft.com`). 2. Log in to that user's My Account portal, navigating to Security Info. 3. Select "Add sign-in method" → "Email." 4. In the email input field, enter the **victim's** email address—not the attacker's.

Step 4 is the payload delivery trigger. When a new email address is added as a backup authentication method, Microsoft's security logic automatically generates and sends a one-time passcode (OTP) to that email address to verify ownership. This is a legitimate, security-motivated workflow. But the notification email Microsoft sends to verify the backup address uses the Tenant Name in both the subject line and the signature block.

The resulting email to the victim has a subject line constructed as:

```
{Tenant Name} account email verification code
```

Which renders as:

```
Your Bitcoin Purchased of USD 498.95 Completed through PayPal. Reach Support Desk at  
802 538 3069 to CanceI or Renew. account email verification code
```

The message body contains the OTP code—a real, functioning verification code issued by Microsoft. The signature block echoes the Tenant Name, reinforcing the fraudulent financial claim. The only URLs in the message body link to privacy.microsoft.com and www.microsoft.com—Microsoft's actual legal and privacy pages, included in the template to provide legal compliance disclosures.

Every element of this email is technically genuine. Every element reinforces the victim's perception that they have received a legitimate Microsoft communication about an alarming, unauthorized financial transaction.

4. Technical Walkthrough of the Attack Chain

4.1 Phase 1: Infrastructure Setup (T-minus Setup)

Step 1: Tenant Provisioning

The attacker registers a new Microsoft 365 tenant—typically using a free trial, a basic subscription, or a test account. These registrations require minimal identity verification and are available globally, making them an essentially unlimited resource. The tenant is assigned a subdomain on `onmicrosoft.com` (e.g., `Williford316.onmicrosoft.com`).

Step 2: Tenant Name Poisoning

Via the Entra ID admin portal → Tenant Properties, the attacker sets the "Name" field to the phishing payload. In observed samples, this was a Bitcoin/PayPal fraud alert with a callback phone number. The phone number itself contains evasion modifications—digits replaced with visually similar letters (e.g., the digit "0" replaced with the capital letter "O") to defeat numeric regex-based keyword filters.

Step 3: Unicode Payload Obfuscation

The tenant name payload uses "ogonek" character substitutions—a diacritic mark used in Polish and Lithuanian that attaches a small hook to the base letter. The character "ą" (a with ogonek, U+0105) is visually nearly identical to "a" (U+0061) in most fonts. By substituting such characters throughout keywords (e.g., "Cancel" using a capital I instead of lowercase l), the attacker constructs text that reads normally to human eyes but breaks signature-based pattern matching and OCR-dependent keyword filters.

Step 4: User Account Batch Creation

Within the malicious tenant, the attacker creates a roster of user accounts—these serve as the "senders" who trigger the notification flow. Account names are typically randomized or drawn from common name databases to appear plausible. The Microsoft Graph PowerShell SDK cmdlet `New-MgUserAuthenticationMethod` enables programmatic creation of these users and pre-configuration of their authentication methods at scale, suggesting the entire setup can be executed in automated batch runs.

4.2 Phase 2: Targeting and Delivery

Step 5: Target Selection

Target email addresses may be sourced from data breaches, purchased email lists, LinkedIn scraping, corporate directory harvesting, or prior phishing campaigns. The attack does not require any pre-existing relationship with the victim organization—any valid email address is a viable target.

Step 6: Security Info Portal Trigger

The attacker (or automated script) logs into `mysignins.microsoft.com/security-info` under one of the

malicious tenant's user accounts, navigates to the "Add sign-in method" → "Email" flow, and enters the victim's email address. This is a standard, legitimate Microsoft security workflow. No rate limiting or verification challenge appears to have prevented this from being automated at scale—a platform gap that Microsoft has since had to consider.

Step 7: Microsoft Generates and Sends the Email

Microsoft's authentication infrastructure automatically generates an OTP and dispatches the verification email to the victim's address. The email originates from `msonlineservicesteam@microsoftonline.com`, Microsoft's legitimate transactional mail infrastructure. The message passes SPF (originating from Microsoft's authorized sending IPs), passes DKIM (signed with Microsoft's domain key), and passes DMARC (both SPF and DKIM align with the microsoftonline.com domain). The template inserts the poisoned Tenant Name into the subject line and signature.

Step 8: Allowlist Bypass

The email arrives at the victim's mail server. Many organizations have explicit allowlist rules for `msonlineservicesteam@microsoftonline.com` or the broader `microsoftonline.com` domain—because blocking legitimate Microsoft authentication notifications creates operational disruption. The allowlisted email bypasses additional scanning layers, often including advanced threat protection rules that might otherwise analyze content more deeply.

4.3 Phase 3: Victim Interaction (TOAD Phase)

Step 9: Victim Reads the Email

The victim sees an alarming subject line claiming an unauthorized cryptocurrency purchase through PayPal, followed by a verification code they did not request. The juxtaposition of two legitimate cognitive triggers—a financial fraud alert and a Microsoft security notification—creates a state of high urgency. Security-aware users may recognize that unsolicited verification codes can indicate account takeover attempts, which paradoxically increases urgency rather than triggering skepticism.

Step 10: Callback

The embedded phone number in the email's subject line and body instructs the victim to contact a "Support Desk" to cancel or dispute the charge. The victim calls. They reach a social engineering operator—a human actor running a vishing script—who presents as either Microsoft Support or a financial institution's fraud prevention team, depending on the specific campaign variant.

Step 11: Credential/Access Harvesting

The operator's script extracts value through several possible pathways: - **Payment credential theft:** The operator claims to need card details to "reverse" the fraudulent charge. - **Remote access installation:** The operator claims to need to "secure the account" and instructs the victim to install remote access software (AnyDesk, TeamViewer, QuickAssist) to allow "technical support." - **Account credential harvesting:** The

operator requests login credentials to "verify identity" or "recover the account." - **Gift card fraud**: A classic advance-fee variant where the victim is instructed to purchase gift cards to "secure" funds during the "investigation."

Step 12: Infrastructure Abandonment

Once the attack wave completes—typically within 24-48 hours of a tenant being provisioned—the attacker abandons the tenant. Free trials expire, accounts become inaccessible, and the infrastructure trail evaporates. This burn-and-churn discipline makes retroactive investigation difficult and infrastructure-based blocking measures ineffective.

4.4 MITRE ATT&CK Framework Alignment

Technique ID	Name	Application
T1566.002	Phishing: Spearphishing Link	Notification delivery triggering callback
T1078.004	Valid Accounts: Cloud Accounts	Attacker-controlled tenant accounts as delivery mechanism
T1036.005	Masquerading: Match Legitimate Name or Location	Tenant name poisoning mimicking legitimate security communications
T1585.001	Establish Accounts: Social Media Accounts	Disposable tenant creation at scale
T1656	Impersonation	Vishing operator impersonating Microsoft/financial institution support
T1598	Phishing for Information	Callback designed to harvest credentials and payment data
T1059.001	PowerShell	Microsoft Graph PowerShell SDK used for automated account provisioning
T1027	Obfuscated Files or Information	Unicode substitution to evade detection

5. Why Traditional Email Security Fails

5.1 The Secure Email Gateway Architecture

The dominant email security model for enterprise organizations over the past decade has been the **Secure Email Gateway (SEG)**—an inline proxy that sits in the mail delivery path, inspecting every inbound and outbound message against a library of threat signatures, URL reputation databases, attachment sandboxes, and rule-based content filters.

SEGs are well-optimized for the threat model they were built to address: messages carrying malicious attachments, links to credential-harvesting pages on attacker-owned domains, or messages spoofing sender addresses in ways that fail authentication checks. For commodity phishing—the kind that arrives in bulk, links to newly registered phishing domains, and contains attachments with macro-enabled Office documents—SEGs remain reasonably effective.

They are structurally blind to the Microsoft notification abuse attack.

5.2 The Five Points of SEG Failure

Failure Point 1: Authentication-Based Trust

Most SEG configurations include explicit pass-through rules for sources that consistently pass email authentication—particularly high-reputation senders like Microsoft. When a message from `msonlineservicesteam@microsoftonline.com` arrives with SPF pass, DKIM pass, and DMARC pass, the SEG's first-line filter passes it as legitimate without deeper inspection. This is not a misconfiguration; it is the intended behavior for operationally critical senders.

Failure Point 2: Absence of Traditional IOCs

SEGs detect threats by finding indicators of compromise: malicious URLs, known-bad IP addresses, suspicious attachment file types, executable payloads, macro-enabled documents. The Microsoft notification abuse email contains none of these. Its only URLs are `privacy.microsoft.com` and `www.microsoft.com`—deeply trusted domains with near-perfect reputation scores. Its "payload" is a phone number embedded in text. There is no file, no link to flag, no known-bad hash to match.

Failure Point 3: Signature and Rule Immobility

Even if a SEG operator discovers and writes a rule to catch the specific subject line pattern used in the Microsoft notification abuse campaign, the attacker's use of Unicode obfuscation (ogonek substitutions) and digit-to-letter phone number encoding ensures the rule fails. The text "Cąncel" bypasses a rule looking for "Cancel." The number "8O2 538 3O69" (capital O instead of zero) bypasses a rule checking for North American phone number formats. Each evasion technique was designed with specific knowledge of how security tooling processes text.

Failure Point 4: Perimeter-Only Visibility

Traditional SEGs operate at the ingress/egress point—they see messages as they enter or leave the organization's mail environment. They do not have visibility into Microsoft's internal tenant-to-user notification flows, cannot analyze the relationship between a notification's structural content and baseline communication patterns, and have no telemetry on what "normal" looks like for a given user's received Microsoft notifications.

Failure Point 5: Static Allowlists

The allowlist—a curated set of senders exempt from filtering—is a fundamental SEG control mechanism. For organizations that depend on Microsoft services for authentication, the `microsoftonline.com` and `microsoft.com` sender domains are almost universally allowlisted for pass-through delivery. This is not unreasonable. What is now clear is that this allowlist is itself an attack surface when those platforms can be manipulated to send malicious content.

5.3 Why Behavioral AI Changes the Calculus

The category of email security that can detect this attack is not rule-based; it is **behavioral AI**—systems that learn organizational communication baselines and identify anomalous content, context, or intent regardless of authentication status.

A behavioral AI system trained on an organization's communication patterns can observe that:

- The organization has never previously received a Microsoft system notification containing financial transaction language, cryptocurrency terms, or a callback phone number.
- The subject line length and structure are anomalous relative to the baseline of Microsoft system notifications received by the organization.
- The combination of "account email verification code" notification type with high-urgency financial language represents a statistically novel pattern.
- Unicode character substitutions within the Tenant Name field represent an anomalous use of diacritical characters inconsistent with the organization's normal communication corpus.

None of these signals requires prior knowledge of the specific attack. They emerge from deviation from learned norms—which is precisely why behavioral AI is the architectural response to a threat that specifically engineers itself to look authentic.

The critical insight is that behavioral AI does not ask "is this message from a trusted sender?" It asks "is this message consistent with what a trusted sender normally sends?" The former question is now trivially defeated. The latter remains meaningful.

6. Trusted Infrastructure as an Attack Surface

6.1 The "Living off Trusted Sites" Threat Category

The Microsoft notification abuse attack belongs to a broader and accelerating threat category that security researchers have begun calling **"Living off Trusted Sites" (LOTS)**—an adaptation of the well-documented "Living off the Land" (LotL) technique from endpoint security, where attackers use native operating system tools (PowerShell, WMI, certutil) to avoid deploying custom malware that might trigger detection.

LOTS applies the same logic to the web and cloud layers: instead of hosting content on attacker-controlled infrastructure that carries reputational risk and will eventually be detected and blocked, attackers use platforms that organizations inherently trust and actively allow through their defenses. The technique exploits the gap between infrastructure reputation and content legitimacy.

The threat category manifests across multiple platforms:

Platform	Exploitation Method	Trust Signal Exploited
Microsoft 365	Tenant branding notification injection (this paper's case study)	Authentication + Allowlist
Google Drive	Phishing pages hosted on legitimate Google Storage URLs	Domain reputation + URL filtering bypass
Canva	Public-facing phishing designs with embedded redirects	Design platform reputation
Dropbox	Malicious file links using <code>dropbox.com</code> URLs	Cloud storage trust
GitHub	Malware hosting, C2 infrastructure via GitHub APIs	Developer platform reputation
SharePoint	Phishing landing pages hosted in legitimate SharePoint tenants	Enterprise productivity trust
DocuSign	Fraudulent e-signature requests from legitimate DocuSign infrastructure	Business process legitimacy
Notion	Phishing pages constructed as Notion public pages	SaaS platform reputation

In each case, the attacker's strategy is identical: don't build your own infrastructure that will be detected—weaponize the infrastructure your targets already trust.

6.2 The Microsoft Ecosystem as an Especially Rich Target

Microsoft's position in the enterprise security landscape makes its infrastructure an especially attractive LOTS target. Consider the scale: as of 2025, Microsoft 365 is the dominant enterprise productivity platform, with over 400 million paid seats globally. The Microsoft identity infrastructure—Entra ID (formerly Azure Active Directory)—is the authentication backbone for the majority of Fortune 500 companies.

This ubiquity means Microsoft system notifications are familiar to virtually every enterprise employee worldwide. The visual language of Microsoft security emails—the blue branding, the security alert iconography, the one-time passcode format—has been normalized through years of legitimate use. It is perhaps the most effective phishing vessel an attacker could choose, because the recipient has likely received dozens of authentic versions of the same communication template.

The Microsoft ecosystem also offers attackers unusual operational leverage: - **Unlimited tenant provisioning:** Anyone with a valid email address can create a Microsoft 365 tenant, including free trials. - **API-accessible management:** The Microsoft Graph API and Graph PowerShell SDK provide programmatic access to tenant configuration, enabling automation at scale. - **Rich notification infrastructure:** Microsoft sends system notifications for authentication events, security changes, subscription notifications, and dozens of other triggers—each a potential delivery vector. - **Trusted by design in most enterprises:** Security teams actively configure their defenses to *not* block Microsoft communications.

6.3 The Teams Vector: A Parallel LOTS Attack Chain

While the notification abuse attack targets email, a closely related attack chain exploits Microsoft Teams using the same LOTS philosophy.

Attackers create malicious Microsoft 365 tenants and configure Teams to reach out to employees of target organizations via the **external tenant collaboration** feature—a legitimate Teams capability that allows cross-organizational communication. The attack proceeds:

1. Attacker creates a tenant with a display name impersonating IT support (e.g., "IT Help Desk" or "Microsoft Support Team").
2. Attacker initiates a Teams message or group chat to the victim's Teams account from the external tenant.
3. The victim receives a legitimate Teams notification from what appears to be an authority figure.
4. The attack proceeds through social engineering: often a "technical emergency" requiring the victim to install QuickAssist (Windows' built-in remote assistance tool) or call a number for "support."

Microsoft documented this attack pattern, attributed it to threat actors tracked under the name "Storm-1811," and noted that it exploited Microsoft's default Teams configuration allowing external communication from any verified tenant. The same trust-exploitation architecture—legitimate platform, legitimate notification, attacker-controlled content—appears across both the email and Teams attack surfaces.

6.4 OAuth Consent Phishing: The Identity Layer LOTS Attack

At the identity layer, a parallel attack class exploits OAuth 2.0's consent architecture. OAuth consent phishing—also called "illicit consent grant" attacks—works by tricking users into authorizing a malicious application to access their Microsoft 365 data. The consent screen is hosted by Microsoft itself (at

`login.microsoftonline.com`), rendered in Microsoft's official UI, and protected by Microsoft's SSL certificate. From the user's perspective, they are interacting with a legitimate Microsoft authorization flow.

Once the user grants consent, the malicious application holds a valid OAuth token—an authorization credential that:

- Persists even if the user changes their password
- Does not require MFA re-challenge for continued use
- Grants delegated access to data through the Microsoft Graph API
- Operates entirely through legitimate Microsoft API calls that blend with normal traffic

This is the identity layer equivalent of the notification abuse attack: the attacker doesn't steal credentials, they get Microsoft's identity infrastructure to issue them legitimate access. SPF, DKIM, and DMARC are irrelevant. The access is authentic. The use is malicious. The authentication stack has no framework for distinguishing between the two.

7. The Psychology of Callback Phishing

7.1 Why Phone Numbers Instead of Links

The decision to use a callback phone number as the payload delivery mechanism—rather than a malicious URL—is not a technical limitation. It is a deliberate psychological and operational choice that makes the attack both more effective against human targets and more evasive against technical defenses simultaneously.

Technically, a phone number in email text is not a threat indicator. No URL scanner will analyze it. No sandboxing system will detonate it. No reputation database has an entry for it. The phone number exists entirely outside the surface area of automated threat detection.

Psychologically, a phone number activates a different cognitive pathway than a suspicious link. Most security-aware users have been trained—through a decade of phishing awareness programs—to approach unexpected email links with skepticism. The heuristic "don't click unexpected links" has been successfully internalized by a meaningful portion of the workforce.

No equivalent heuristic exists for "don't call unexpected phone numbers." The absence of a trained skeptical reflex, combined with the urgency and authority signals embedded in the message, makes phone-based social engineering disproportionately effective on users who would successfully resist a link-based attack. This is not a coincidence. It is the design of the attack.

7.2 The Persuasion Architecture: Urgency, Authority, and Cognitive Dissonance

The Microsoft notification abuse email deploys a carefully constructed persuasion architecture that exploits three of the most powerful psychological compliance triggers—drawn directly from Cialdini's influence framework—simultaneously:

Authority: The message arrives from Microsoft. Not from an email claiming to be from Microsoft—from Microsoft's actual infrastructure. The sender domain, the Microsoft template formatting, the legitimate Microsoft URLs in the footer—every visual and technical element reinforces Microsoft's authority. For most enterprise employees, Microsoft represents the highest possible authority over their account security. Compliance with authority figures is deeply ingrained in organizational cultures.

Urgency: The message claims an unauthorized financial transaction has already occurred. Not "may occur" or "is pending verification"—the language implies the transaction is complete and irreversible unless action is taken immediately. This creates what psychologists call "cognitive tunneling"—the brain narrows its focus to the single

imperative of resolving the urgent problem, suppressing the deliberative thinking that would otherwise recognize the social engineering attempt.

Cognitive Dissonance: Perhaps the most sophisticated element is the juxtaposition of the fraudulent financial claim with a legitimate OTP verification code. The victim receives what looks like a security verification email—something that should reassure—but the content is alarming. This creates cognitive dissonance: two conflicting signals that the brain must resolve. The attacker's goal is for the victim to resolve that dissonance by calling the number, which is framed as the logical action to "sort out" the contradiction.

Security-aware employees may recognize the OTP as a warning sign—unsolicited verification codes often indicate that someone is attempting to access your account. This recognition does not reduce the attack's effectiveness; in this case, it may amplify it. The victim thinks: "Someone is trying to register my email to their account *and* charge my PayPal. This is definitely a fraud emergency—I need to call immediately."

7.3 The BazaCall Lineage

The callback phishing technique documented in this campaign is not new to the threat landscape. It traces its lineage directly to **BazaCall** (also written BazarCall), a campaign first observed in 2020-2021 that pioneered the telephone-oriented attack delivery model. BazaCall was notable for:

- Sending victims fake subscription cancellation emails with callback numbers
- Using professional call center operators to walk victims through installing BazaLoader malware
- Serving as an initial access vector for Conti and Ryuk ransomware groups

The connection is significant: callback phishing was not invented by opportunistic consumer fraud operations. It was developed and operationalized by sophisticated ransomware groups with the capability to convert initial access into enterprise-wide ransomware deployments. The technique graduated from ransomware initial access to consumer fraud, but the operational sophistication of its originators shaped the technique's architecture in ways that persist in current campaigns.

By 2024-2025, callback phishing had become a standard component of the Phishing-as-a-Service (PhaaS) ecosystem, with multiple toolkits offering turnkey phishing operation capabilities. The VENOM platform, mentioned by Abnormal AI researchers in their report, specifically targets C-suite executives and hijacks live Microsoft sign-ins and OAuth tokens—demonstrating that the callback phishing ecosystem has evolved beyond consumer fraud into enterprise-grade credential compromise operations.

7.4 The Human-in-the-Loop Advantage

One often underappreciated advantage of callback phishing over automated attacks is the presence of a human social engineering operator in the final stage. Automated phishing relies on static scripts that cannot adapt to the

victim's responses—a suspicious question, an unexpected answer, or a request for verification can break the automated flow.

A human operator can adapt in real time. They can address doubts, provide reassurance, adjust their authority level (escalating from "support agent" to "senior specialist" to "supervisor" if needed), and apply targeted social pressure based on the victim's emotional state. This adaptability makes callback phishing disproportionately effective against security-aware targets who might successfully identify and resist a purely automated attack.

The combination of technical authenticity (Microsoft's own infrastructure delivering the lure) with human adaptability in the endpoint interaction creates an attack that is simultaneously hard to detect technically and highly effective socially. It represents the intersection of infrastructure exploitation and human manipulation at their respective optimal forms.

8. Unicode Obfuscation and Detection Evasion

8.1 The Three Evasion Mechanisms

The Microsoft notification abuse campaign deploys three distinct and orthogonal technical evasion mechanisms, each targeting a different layer of the security detection stack. Their simultaneous deployment indicates sophisticated adversarial knowledge of defensive tooling.

Mechanism 1: The Subject Line Hijack

By injecting 60+ characters of scam text into the Tenant Name field, the attacker exploits the finite display space of email client subject line previews. On most email clients and mobile interfaces, the subject line preview truncates after approximately 60-80 characters. By constructing a long tenant name, the attacker ensures that the fraudulent financial alert text appears in the preview window while the template-appended text ("account email verification code") is pushed out of visible range.

The victim sees the alarm in the preview. The legitimate template text becomes invisible until the email is opened. This manipulation of *what is visible before engagement* is a technique derived directly from long-subject-line spam, but applied with precision to Microsoft's specific template structure.

Mechanism 2: Ogonek Character Substitution

The ogonek is a diacritical mark from Central and Eastern European scripts—specifically Polish and Lithuanian typography—that attaches a small hook to the base of certain vowels. The character "ą" (U+0105, LATIN SMALL LETTER A WITH OGONEK) is rendered by most fonts as visually indistinguishable from "a" (U+0061) at standard email body text sizes.

By substituting ogonek variants for standard Latin characters in keywords likely to trigger detection rules—such as "Bitcoin," "PayPal," "cancel," "purchased"—the attacker constructs text that:

- Reads identically to the human eye in the rendered email client view
- Differs at the Unicode codepoint level from the string a keyword filter would match
- Breaks OCR-based text extraction that attempts to normalize the text before applying keyword rules

This is not a novel technique. Unicode homoglyph attacks have been documented in academic security research for over a decade, and Punycode homograph attacks against domain names have been operationally deployed for years. What is significant here is the application of the technique *within a legitimate platform's own notification infrastructure*—using the feature (Tenant Name customization) to inject the obfuscated text, so the obfuscation is embedded in Microsoft's own template output.

Mechanism 3: Digit-to-Letter Phone Number Encoding

Phone numbers in email text are the payload's most functionally critical element—the string the victim uses to

make the callback. Standard security detection mechanisms that look for phone number patterns in email text use regular expressions that match digit sequences in recognized formats (e.g., `\d{3}[-.\s]\d{3}[-.\s]\d{4}` for North American numbers).

By substituting digits with visually similar letters—most commonly replacing "0" (zero) with "O" (capital letter O) and "1" (one) with "l" (capital letter l or "l" lowercase L)—the attacker creates a string that:

- Looks like a phone number to the human reader
- Does not match a numeric regex pattern
- Cannot be dialed programmatically from a security scanning context

The specific documented example from the campaign—"Cancel or Renew" using capital l instead of lowercase l—demonstrates this technique applied to the action verb, not just the phone number. The effect is visible only at the Unicode codepoint level; the rendered character appears identical in the email client.

8.2 The Arms Race Dimension

These three techniques exist because defenders have, at various points, deployed the countermeasures that made them necessary. The existence of OCR-based text normalization in email security platforms prompted Unicode obfuscation. The existence of phone number regex detection prompted digit-to-letter substitution. The existence of subject line keyword filters prompted the 60+ character hijack.

This adaptive development pattern indicates the presence of a feedback loop: threat actors test campaigns against security tools (potentially through deliberate adversarial testing or through analysis of campaign efficacy), identify detection chokepoints, and engineer evasion mechanisms specifically to defeat those chokepoints.

The implication for defenders is significant: rule-based detection mechanisms are not just ineffective against this attack—they are the *inputs* that shaped the attack's design. Writing new rules to catch this specific campaign will prompt refinement of the evasion technique in the next campaign variant. The only detection approach that breaks this cycle is one that does not rely on rules the attacker can enumerate and evade—which returns us to behavioral AI as the necessary architectural response.

8.3 Invisible Unicode: The Next Evolution

Researchers monitoring adjacent campaigns have documented an emerging technique that represents the next evolution of Unicode-based evasion: the use of **invisible Unicode characters** to hide code or text entirely.

Specifically, Hangul half-width (U+FFA0) and Hangul full-width (U+3164) characters are rendering-invisible in most contexts—they occupy space but display nothing. Attackers have used these characters to encode malicious payloads as binary strings of visible/invisible characters, which are then reconstructed at runtime by

bootstrap JavaScript using Proxy `get()` traps. The encoded payload appears as empty whitespace in static analysis tools, HTML viewers, and email client renderings.

Applied to the notification abuse context, this technique could allow future variants to embed obfuscated payloads that are entirely invisible to human inspection—requiring sophisticated Unicode normalization and invisible character detection in security tooling to surface.

9. Disposable Cloud Infrastructure Operations

9.1 The Burn-and-Churn Economic Model

The operational model of the Microsoft notification abuse campaign—provisioning disposable tenants, launching attack waves, and abandoning the infrastructure before detection and takedown—mirrors the broader "burn-and-churn" operational philosophy that has become standard in sophisticated cybercriminal operations.

The economic logic of burn-and-churn is compelling. Traditional infrastructure-based security controls depend on: 1. Identifying malicious infrastructure (domains, IPs, cloud tenants) 2. Blocking or taking down that infrastructure 3. Preventing subsequent attacks from the same infrastructure

Burn-and-churn attacks collapse this dependency chain. If each piece of infrastructure is used for 24-48 hours and then abandoned, it becomes functionally impossible to build an effective blocklist. By the time security researchers identify a malicious tenant, analyze its behavior, report it to Microsoft, and await remediation—the tenant has already been abandoned and replaced by a new one.

The math strongly favors the attacker: creating a new Microsoft 365 free trial takes minutes. Provisioning 10-20 accounts within it takes additional minutes via automation. Launching a notification attack wave against a target list takes seconds. The total cost—time and resources—of establishing and using one malicious tenant is measured in minutes of automated script execution. The cost to Microsoft and to defenders of detecting, reporting, and remediating that tenant is measured in hours to days of analyst time.

This asymmetry is not a gap that can be closed through manual processes. It can only be addressed through automated detection at Microsoft's infrastructure layer—specifically, anomalous use of tenant branding fields and the Security Info portal's backup email registration workflow.

9.2 Microsoft 365 Free Trials as Attack Infrastructure

The specific attack infrastructure used—Microsoft 365 free trial tenants registered on `onmicrosoft.com` subdomains—deserves particular examination because it represents a structural tension in cloud platform business models.

Microsoft's free trial program exists to convert potential customers. The program intentionally minimizes friction: creating a trial tenant requires only a valid email address (which itself can be a disposable temporary address), basic contact information that is not verified against real identity documents, and acceptance of the Terms of Service. This low-friction onboarding is commercially necessary—excessive verification requirements would reduce trial signups and hurt conversion rates.

But minimal friction onboarding means that the resources provisioned through that process—including the tenant itself, its admin capabilities, its Graph API access, and its ability to send notifications through Microsoft's infrastructure—are available to anyone with a disposable email address. The commercial imperative for frictionless onboarding creates a security externality: the operational infrastructure that legitimate customers value is also available to adversaries at essentially zero cost.

This is not a flaw unique to Microsoft. Every major SaaS platform faces the same tension. Google's free Gmail and Google Workspace trials, Slack's free workspaces, Notion's free accounts, and GitHub's free repositories all provide legitimate infrastructure that attackers have learned to exploit for LOTS campaigns. The structural response—adding identity verification that meaningfully increases friction for malicious actors without proportionally degrading legitimate user experience—is an unsolved problem at industry scale.

9.3 Automation via Microsoft Graph PowerShell SDK

The Microsoft Graph PowerShell SDK (`Microsoft.Graph`) is Microsoft's official, supported toolset for programmatic management of Microsoft 365 environments. It provides administrative access to virtually every tenant management function—user creation, permission assignment, authentication method configuration, group management, and more—through a consistent PowerShell API.

The specific cmdlet identified in the notification abuse campaign is `New-MgUserAuthenticationMethod` , which programmatically configures authentication methods for user accounts. This cmdlet enables: - Bulk creation of user accounts with pre-configured authentication methods - Automated registration of email addresses as backup authentication contacts - Batch processing of authentication configuration changes across multiple accounts

An attacker who has scripted the full provisioning workflow—tenant creation, branding configuration, user account generation, backup email registration via `New-MgUserAuthenticationMethod` —can execute a complete attack wave in a single automated run. The Microsoft Graph API imposes rate limits, but they are designed for administrative efficiency rather than security against adversarial automation; sophisticated operators can distribute requests across multiple tenant accounts to stay within rate limits while maintaining high throughput.

This level of automation capability is what transforms what might otherwise be a manually executed, low-volume attack into the industrialized 2,000+ message campaign documented by Abnormal AI. The attack scales linearly with the number of script execution threads.

9.4 Infrastructure Forensics: What Investigators Actually Find

When a security operations team investigates a Microsoft notification abuse complaint, the evidentiary trail is deliberately minimal:

- The email's sending infrastructure is Microsoft's own—no attacker-controlled mail server to block or report.
- The Microsoft tenant used to trigger the notification likely no longer exists by the time of investigation.
- The user accounts within the tenant were disposable and are no longer accessible.
- The only concrete attacker artifact—the phone number embedded in the subject line—is trivially replaceable via a new virtual number provider.
- The OTP code delivered to the victim is time-limited and functionally inert after use.

Traditional incident response frameworks assume that investigation yields artifacts that enable blocking, attribution, and prevention of future attacks. The burn-and-churn model is explicitly designed to leave no such artifacts. This is not incidental operational security—it is the architecture of a campaign designed to operate below the threshold of effective response.

10. SaaS Ecosystem Abuse Trends

10.1 The Expanding LOTS Attack Surface

The Microsoft notification abuse campaign is best understood not as an isolated technique but as the leading edge of a broader expansion in SaaS ecosystem abuse. As enterprise security has hardened the traditional attack surface—endpoints, perimeter networks, attachment-based phishing—attackers have systematically shifted toward the surface that is simultaneously most trusted and least scrutinized: the SaaS ecosystem.

The pattern is consistent across platforms: attackers identify legitimate features that generate user-facing notifications, discover ways to inject attacker-controlled content into those notifications, and weaponize the platform's own infrastructure and reputation as a delivery mechanism. The specific mechanism varies by platform; the strategic logic is identical.

Google's Notification Infrastructure: Google Workspace and Gmail's "Share" notifications—alerts sent when someone shares a Google Drive document or adds a user to a Google Calendar event—have been exploited in campaigns that create malicious Docs or Forms and then share them with targets. The notification email arrives from `no-reply@google.com`, passes full authentication, and contains a legitimate Google Drive link that leads to a phishing page constructed within Google's own document infrastructure.

DocuSign Workflow Abuse: Attackers have created fraudulent DocuSign envelopes using legitimate DocuSign accounts, sending official DocuSign signature requests to targets. The notifications arrive from `dse@docusign.net`, pass authentication, carry DocuSign's branding and security assurances, and link to a legitimate DocuSign signing session that captures credentials or leads victims through a social engineering script.

Canva and Design Platform Abuse: Canva's platform allows creation of public-facing design assets with embedded links. Attackers create professional-looking phishing pages within Canva and share them via Canva's own notification infrastructure, or host them at `canva.com` URLs that bypass URL reputation filters.

GitHub as C2 Infrastructure: Sophisticated threat actors have used GitHub repositories and GitHub Gist as command-and-control infrastructure, using the GitHub API to receive operator instructions and exfiltrate data. GitHub's API traffic blends with the enormous volume of legitimate developer activity, making network-level detection effectively impossible without application-layer inspection.

10.2 The Trust Inheritance Problem

The common thread across all LOTS campaigns is what might be called **trust inheritance**: when a malicious payload is delivered through a trusted platform's infrastructure, it inherits the trust relationship that exists

between that platform and the target organization.

This trust inheritance operates at multiple layers simultaneously: - **Technical**: The message passes the authentication checks that legitimate messages from that platform pass. - **Reputational**: Security tools that score domains and IPs against reputation databases score the platform's infrastructure as high-reputation. - **Organizational**: Security teams have configured allowlists and pass-through rules for platforms the organization actively uses. - **Human**: End users recognize the platform's branding and notification format from legitimate use, reducing their suspicion.

Breaking the attack requires breaking all four layers of trust inheritance simultaneously. Technical authentication is inherent to the attack's design and cannot be negated. Reputational scoring correctly identifies the infrastructure as high-reputation, because it is. Organizational allowlists can potentially be revisited, but removing allowlists for platforms employees depend on creates operational disruption. Human recognition is the hardest layer to address through training, because the emails look and feel exactly like legitimate platform communications—because they are.

10.3 The Platform Responsibility Question

The industrialization of SaaS ecosystem abuse raises an uncomfortable but important question about platform responsibility. Microsoft, Google, DocuSign, Canva, and every other platform whose infrastructure is weaponized for LOTS attacks are not passive victims. They control the platforms being exploited, and the exploitation often uses features they designed—Tenant Name customization, email verification workflows, document sharing notifications.

This does not mean these features should not exist. Tenant Name customization serves legitimate organizational needs. Email verification is a security control. Document sharing notifications enable collaboration. But the design of these features did not adequately account for adversarial use cases—specifically, the possibility that an actor would provision these features with the explicit intention of weaponizing the platform's notification infrastructure.

Platform-level countermeasures that could reduce the attack surface include: - **Content validation on Tenant Name fields**: Pattern matching for phone numbers, financial transaction language, cryptocurrency terminology, or other known-bad patterns. - **Rate limiting on Security Info email registration**: Limiting how many distinct email addresses can be registered as backup contacts from a single tenant within a time window. - **Anomaly detection on new tenant provisioning patterns**: Flagging tenants whose configuration patterns match known malicious templates. - **Verification requirements for high-risk features**: Requiring stronger identity verification before enabling features that can trigger notifications to external addresses.

Microsoft has acknowledged this attack class and has implemented or is developing platform-level mitigations. The systemic challenge is that validation and rate-limiting measures that catch malicious use must be carefully

calibrated to avoid breaking legitimate use cases at the scale of millions of tenants.

[Sections 11–17 and Appendices to follow]

11. AI and the Industrialization of Social Engineering

11.1 What Generative AI Changes

The Microsoft notification abuse attack described in this paper is already automated. The attacker scripts tenant creation, branding poisoning, and victim targeting. But the human-facing elements—the vishing script, the social engineering operator's responses, the construction of plausible lure text—still require human labor. Generative AI is in the process of removing that constraint.

By 2025, security researchers reported that more than 82% of phishing emails incorporated AI in some form—for text generation, personalization, obfuscation, or lure construction. AI-crafted phishing messages achieve click-through rates approaching 54%, compared to roughly 12% for human-crafted phishing. The gap is attributable to LLMs' ability to produce grammatically precise, contextually coherent text at scale, with none of the spelling errors and stilted phrasing that security awareness training has trained employees to notice.

For trusted infrastructure phishing specifically, generative AI addresses the two remaining bottlenecks: **lure personalization** and **vishing operator scalability**.

11.2 AI-Personalized Lures at Scale

The notification abuse attack as documented uses a generic lure—a Bitcoin/PayPal charge for a fixed dollar amount. This works because urgency and authority carry the attack even without personalization. But the technique's effectiveness ceiling is set by the credibility of the lure.

A generative AI-enhanced variant constructs lures from OSINT: the target's name, employer, recently detected financial activity patterns (available from data breach corpora), regional payment platforms, and linguistic patterns that match the target's communication style. The tenant name field that carries the payload can be populated dynamically—different financial claim amounts, different platform names, different contextual details—for each individual target on a list.

At current LLM API pricing, generating a uniquely personalized phishing payload for ten thousand targets costs less than \$50 in compute. This eliminates the traditional tradeoff between scale and personalization. Mass phishing used to mean generic lures. AI-enabled mass phishing means individualized lures at the same cost.

11.3 AI-Powered Vishing: The Operator Replacement

The most consequential near-term AI development for this attack class is the **automated vishing operator**. The callback phishing model currently requires human operators—a real person answering the phone, running a social engineering script, adapting to the victim's responses. This is the cost center in the operation: it requires

recruiting and training call center staff, managing quality, and operating at the scale the human workforce can support.

Voice-cloning and conversational AI can eliminate this bottleneck. Systems built on large language models with voice synthesis capabilities can now conduct real-time telephone conversations, respond to unexpected questions, handle objections, and adjust tone and urgency in response to the conversational context—without a human operator. The voice can be cloned from a small audio sample to match a known authority figure (IT support, a bank representative, a Microsoft spokesperson).

The VENOM platform identified by Abnormal AI researchers—targeting C-suite executives and hijacking Microsoft sign-ins and OAuth tokens—represents the advanced end of this progression. A system that combines AI-personalized lure delivery through trusted infrastructure with AI-powered vishing eliminates virtually all human labor from the attack chain while dramatically improving per-target effectiveness.

11.4 Polymorphic Campaign Generation

AI also addresses a core detection vulnerability: campaign fingerprinting. Traditional threat intelligence builds detection rules around recurring patterns—specific subject line structures, payload formats, phone number ranges, obfuscation character sets. These patterns persist because human operators construct campaigns manually and reuse effective templates.

AI-generated campaigns can be **polymorphic**: each message variant is semantically equivalent but syntactically distinct. Subject line structure varies. Financial platform names rotate. Dollar amounts randomize. Obfuscation character choices vary across Unicode character sets. Phone number formats shift between encoding schemes. The underlying attack intent is constant; the observable surface changes continuously.

Polymorphic generation collapses the utility of signature-based detection entirely. Every static rule becomes outdated the moment the AI generates the next campaign variant—which happens automatically, continuously, and at zero marginal cost.

11.5 The Strategic Implication: Speed Asymmetry

The asymmetry between AI-powered attack generation and human-speed defense construction is the central strategic challenge of the next phase of this threat. An AI system generating polymorphic campaign variants can outpace a human analyst writing detection rules by several orders of magnitude. The only architecturally viable response is AI-powered defense: behavioral models that detect intent and anomaly rather than pattern, operating at machine speed rather than analyst speed.

This is not a theoretical future state. It is the current trajectory. The window between AI attack capability and AI defense capability deployment is narrowing, and organizations that have not invested in behavioral AI-based

email and identity security are already operating with a meaningful defense gap.

12. Strategic Implications for Enterprise Security

12.1 The Allowlist Audit Imperative

The first immediate strategic implication of the Microsoft notification abuse campaign is the need for a fundamental audit of sender allowlists. Most organizations have accumulated allowlist entries over years—added by IT staff when employees complained that legitimate Microsoft communications were being blocked, added by vendors who required pass-through delivery for their services, added by security tools that auto-populate allowlists for known high-reputation senders.

These allowlists are now attack surfaces. An allowlist entry for `microsoftonline.com` effectively exempts every message that can be triggered from a Microsoft 365 tenant from content-level scrutiny. That exemption was reasonable when only Microsoft could provision tenants. It requires reconsideration now that tenant provisioning is available to adversaries at zero cost.

The allowlist audit should ask three questions for each entry: (1) Is there a legitimate operational requirement for this sender's messages to bypass content inspection? (2) Can that operational requirement be met with more targeted exemptions—specific subject line patterns rather than entire sender domains? (3) What is the risk profile of this exemption given that this sender's infrastructure could potentially be co-opted for trusted infrastructure attacks?

12.2 Zero Trust's Identity Blind Spot

The broader strategic implication of the LOTS attack class—notification abuse, OAuth consent phishing, Teams external tenant attacks—is a fundamental gap in how Zero Trust architectures are implemented in practice.

Zero Trust's governing principle—"never trust, always verify"—has been operationalized primarily around network access and device posture. The microsegmentation, conditional access policies, and device compliance requirements that form the backbone of most Zero Trust implementations are well-designed to prevent unauthorized lateral movement *after* initial access.

They do not help when the initial access is achieved through means that the Zero Trust architecture was designed to approve. An OAuth token obtained through consent phishing is a legitimate token—the Zero Trust policy engine sees it as an authorized access request and approves it. A Microsoft system notification arriving from `msonlineservicesteam@microsoftonline.com` is from a trusted sender—the Zero Trust email policy treats it accordingly.

The missing dimension is **content legitimacy verification**—a layer of scrutiny that asks not just "is this access request from an authenticated entity?" but "is this access request consistent with the behavioral baseline of that

entity?" This is the Zero Trust principle applied to message content rather than network access: never trust the content of a message purely because its origin is authenticated; always verify against behavioral norms.

12.3 The CISO's Response Framework

For CISOs processing the strategic implications of this threat class, several immediate and medium-term responses are warranted:

Immediate (0-30 days): - Audit sender allowlists and remove or scope-narrow any blanket domain exemptions for Microsoft, Google, DocuSign, or other major SaaS providers. - Review whether behavioral AI email security is deployed and whether it has visibility into Microsoft 365 internal notification flows via API integration. - Issue security awareness communication to employees specifically addressing the trusted infrastructure phishing threat: emphasize that an email from Microsoft can still contain a scam, and that any unsolicited notification containing a phone number should trigger verification before calling.

Medium-term (30-90 days): - Evaluate Microsoft Entra ID conditional access policies for risky sign-in patterns associated with external tenant authentication attempts. - Review Microsoft Teams external communication settings: restrict external tenant access to specific verified partner domains rather than allowing open external communication. - Assess OAuth application consent policies: disable user-level consent for third-party applications and require admin approval for all consent grants.

Strategic (90+ days): - Reframe the organization's security awareness training paradigm to include "trusted platform skepticism"—training employees that authentication does not imply legitimacy. - Invest in threat intelligence partnerships that provide early visibility into emerging notification abuse campaign patterns. - Establish a formal SaaS security posture management (SSPM) capability to continuously monitor connected SaaS applications, OAuth grants, and tenant configurations for anomalous patterns.

12.4 Cloud Ecosystem Trust Architecture

The deeper strategic question raised by this attack class is whether the cloud ecosystem's current trust architecture—built on the assumption that platform identity implies content integrity—is sustainable. The answer is clearly no, and the industry is beginning to recognize it.

The response will likely unfold across three dimensions: platform controls (Microsoft and others adding content validation to notification pipelines), detection tooling (behavioral AI becoming the standard rather than the exception in enterprise email security), and authentication evolution (identity systems developing richer signals about the *context* and *consistency* of access requests, not just their cryptographic validity).

13. Detection Engineering Opportunities

13.1 The Detection Signal Landscape

Despite the attack's sophisticated evasion design, it does generate detectable signals—they simply require different detection approaches than traditional rule-based systems use. The following detection opportunities are available to organizations with appropriate tooling.

13.2 Behavioral Baseline Deviation Signals

Signal 1: Anomalous Tenant Name Content in Microsoft Notifications

Microsoft system notification emails follow predictable subject line patterns. A behavioral baseline of Microsoft system notifications received by the organization will establish the normal subject line format: short organizational identifiers followed by notification type text. A subject line beginning with 60+ characters of financial alert text before the standard notification type text is a statistically extreme outlier from this baseline.

Detection query (conceptual): Flag Microsoft system notification emails where the subject line content before the first occurrence of standard notification type strings ("verification code," "sign-in," "security info") exceeds a character length threshold (e.g., 40 characters) or matches financial alert semantic patterns (cryptocurrency terms, payment platform names, dollar amounts).

Signal 2: Unicode Character Anomaly in Notification Subject Lines

Standard Microsoft system notifications are generated by Microsoft's own templating system and contain only standard ASCII or well-formed organizational branding characters. The presence of diacritical characters (particularly ogoneks: U+0105, U+0119, U+012F, U+0173, U+0105) in the subject line of a Microsoft system notification is anomalous—Microsoft's template generates the boilerplate text in ASCII, and the only variable input is the Tenant Name. Diacritical characters in that position indicate Unicode obfuscation in the tenant name.

Detection query (conceptual): Inspect Microsoft authentication notification subject lines for Unicode characters outside the Basic Latin block (U+0000–U+007F) in the pre-notification-type segment of the subject.

Signal 3: Phone Number Patterns (Including Letter-Substituted Variants)

The payload is a phone number. Even with digit-to-letter substitution, the structural pattern of a North American phone number (N-digit area code, hyphen or space, N digits, hyphen or space, N digits) is partially preserved. Detection rules should include variants that account for common substitutions: O for 0, I or l for 1, S for 5, B for 8.

Detection query (conceptual): Apply fuzzy phone number pattern matching that normalizes common letter-for-digit substitutions before applying the regex pattern. This approach catches obfuscated numbers while remaining

resistant to further obfuscation only if additional substitution characters are added.

Signal 4: Unsolicited Security Info Registration Notifications

Microsoft sends backup email verification codes only when a user attempts to add an email address as an authentication method. An employee receiving such a notification without having initiated the action should be a high-confidence indicator of either a targeted attack or account compromise. Organizations with SIEM visibility into Microsoft Entra sign-in logs can correlate email delivery events with Security Info registration activity in the tenant to identify cases where the registration attempt originated from an external tenant.

Signal 5: Volume Anomaly in Microsoft Notification Receipt

Organizations in a targeted campaign will see a spike in Microsoft system notification emails—specifically OTP verification messages—from unfamiliar tenant subdomains. Monitoring for unusual volumes of Microsoft authentication notification receipts, particularly from tenants not previously associated with the organization's partners or vendors, provides an early warning signal.

13.3 SIEM Detection Rules

For organizations with Microsoft Sentinel or equivalent SIEM with M365 log integration, the following detection logic applies:

```
// Detect Security Info email registration from external tenants
SecurityAlert
| where AlertName == "Suspicious backup email registration"
| join kind=leftouter (
    AuditLogs
    | where OperationName == "Update user"
    | where TargetResources contains "emailAddress"
    | extend InitiatingTenant = tostring(parse_json(AdditionalDetails)[0].value)
) on CorrelationId
| where InitiatingTenant !contains "yourorganization.onmicrosoft.com"
| project TimeGenerated, UserPrincipalName, InitiatingTenant, OperationName
```

```
// Detect unusual volume of Microsoft OTP notifications to users
EmailEvents
| where SenderFromAddress contains "msonlineservicesteam"
| where Subject contains "verification code"
| summarize NotificationCount = count() by bin(Timestamp, 1h), RecipientEmailAddress
| where NotificationCount > 3 // Threshold tunable per org baseline
| project Timestamp, RecipientEmailAddress, NotificationCount
```

13.4 Endpoint and Network Signals

The vishing phase of the attack (the callback) generates signals at the endpoint and network level:

- Unexpected installation of remote access tools (AnyDesk, TeamViewer, QuickAssist) shortly after a user reports receiving a suspicious Microsoft notification.
- Outbound calls from corporate phone systems or softphones to numbers matching the obfuscated phone number pattern in flagged notification emails.
- LSASS access or credential dumping activity following QuickAssist session initiation—a pattern consistent with the attacker installing remote access for secondary exploitation.

14. Defensive Recommendations

14.1 Platform Configuration Hardening

Microsoft Entra ID / Microsoft 365

Restrict external Teams communication:

In the Teams Admin Center → External Access, change the default from "Allow all external domains" to "Allow only specific external domains." Add verified partner domains explicitly. This eliminates the Teams external tenant attack vector for unauthorized tenants.

Restrict OAuth application consent:

In Entra ID → Enterprise Applications → Consent and Permissions: disable user consent for applications from unverified publishers, and require admin consent workflow for all third-party application consent requests. Enable admin consent workflow notifications so security teams review consent grant requests before approval.

Enable Security Defaults or Conditional Access for MFA:

Ensure phishing-resistant MFA (FIDO2 keys, certificate-based authentication) is enforced for all privileged accounts and progressively for all users. Enable number matching in the Microsoft Authenticator app to defeat MFA fatigue push bombing attacks alongside this threat class.

Monitor Entra ID audit logs:

Configure alerts for: new external authentication method registrations, Security Info changes initiated from unfamiliar tenants, and new OAuth application consent grants with broad permissions (Mail.Read, Files.ReadWrite, Directory.Read.All).

14.2 Email Security Architecture

Move beyond static allowlists:

Replace blanket sender domain allowlists for Microsoft and other SaaS platforms with more surgical exemptions scoped to specific notification types. If `msonlineservicesteam@microsoftonline.com` must be allowlisted, scope the exemption to messages where the subject matches the expected format pattern—and route any that don't match the pattern to the behavioral inspection layer rather than pass-through delivery.

Deploy behavioral AI email security with Microsoft 365 API integration:

Behavioral AI platforms that integrate via the Microsoft 365 API (rather than sitting inline as a SEG) have visibility into the full Microsoft notification flow and can establish baselines for what Microsoft system notifications normally look like for the organization. This is currently the only detection architecture that reliably catches trusted infrastructure phishing variants.

Configure Unicode normalization in content inspection:

Ensure email security tooling applies Unicode normalization (NFKD or NFC normalization) before applying keyword-based detection rules, and flags messages containing unusual Unicode character distributions—particularly diacritical characters in subject lines from high-reputation senders.

14.3 Security Awareness Training

Traditional phishing awareness training is necessary but insufficient for this threat class. Supplementary training should specifically cover:

The "Trusted Platform Scam" concept:

Employees need to understand that an email from Microsoft's actual infrastructure can still contain a scam. The training message: "The sender address is genuine. The email format is genuine. The verification code is genuine. But the subject line text was inserted by a criminal. Authenticity of the channel does not guarantee legitimacy of the content."

Callback number skepticism:

Train employees to never call a phone number included in an unsolicited notification email—regardless of how legitimate the email appears. If a financial charge appears on a statement, call the platform's official support number (found on the platform's website or the back of the card), not the number in the email.

Unsolicited OTP awareness:

An OTP verification code that the user did not request is a signal that someone is attempting to register their email address to another account. Employees should be trained to report these to the security team immediately rather than dismissing them or—worse—calling the scam number included in the same email to "resolve" them.

14.4 Incident Response Preparation

Prepare IR playbooks specifically for trusted infrastructure phishing scenarios: - **Triage:** Confirm whether the Microsoft notification email was legitimate but contained a poisoned Tenant Name (notification abuse) vs. a spoofed Microsoft email (domain impersonation). Check Entra ID audit logs for Security Info registration events targeting the victim's address. - **Containment:** If the victim made the callback and provided information, treat it as a potential credential compromise and remote access compromise simultaneously. Revoke active sessions, rotate credentials, scan for installed remote access tools. - **Reporting to Microsoft:** Report the abusive tenant via Microsoft's abuse reporting channel (abuse@microsoft.com). While the tenant may already be abandoned, reporting contributes to pattern recognition for Microsoft's own abuse detection systems. - **User notification:** Inform affected users about the specific mechanism—that Microsoft's own infrastructure sent the scam—to prevent the confusion and trust erosion that often follows when users don't understand how a legitimate-looking Microsoft email turned out to be malicious.

[Sections 15–17 and Appendices to follow]

15. Future Threat Forecasting

15.1 The Attack Surface Will Expand Before It Contracts

The Microsoft notification abuse technique will proliferate before platform-level mitigations mature. The disclosure of a working technique—particularly one as operationally clean as tenant name poisoning—invariably triggers rapid adoption by threat actors who were not previously using it. Security researchers publishing this analysis (and Microsoft's own disclosure) are simultaneously educating defenders and providing a roadmap for adversaries who hadn't yet discovered the technique independently.

Near-term variants will likely include:

- **Cross-platform expansion:** The same "inject payload into platform's own notification template" logic applies wherever a SaaS platform allows user-controlled text to be inserted into system notification templates. Security researchers and threat actors are now actively looking for equivalent features across other major platforms—Slack workspace names, Zoom account display names, DocuSign custom message fields.
- **Target scope expansion:** Current campaigns appear focused on consumer financial fraud via callback. The same infrastructure could trivially be used for enterprise credential phishing: instead of a Bitcoin charge, the payload becomes an "account security alert" prompting the victim to call a number that will social-engineer them into providing corporate credentials or completing an MFA approval.
- **Hybrid attacks:** Combining notification abuse with OAuth consent phishing in a multi-step sequence—using the trusted notification to establish urgency, then directing the victim to a "remediation portal" hosted on legitimate Microsoft infrastructure that captures an OAuth consent grant.

15.2 AI-Operated Call Centers

The near-term evolution that most significantly changes the economics of this attack is the replacement of human vishing operators with AI. As conversational AI and voice synthesis mature, the marginal cost of handling a callback drops toward zero. An attacker who can automate the entire chain—from tenant provisioning through email delivery to callback handling—can run campaigns at arbitrarily large scale with minimal ongoing operational cost.

This transition will likely happen progressively: AI-assisted operators (where AI suggests responses in real time to a human agent) are already in use in legitimate call center contexts; full AI automation of simple social engineering scripts is the near-term endpoint. The barrier is the complexity of the social engineering conversation required—simple credential request scripts will be automated before complex multi-step manipulation sequences.

15.3 Platform Counter-Measures and Their Limits

Microsoft and other platforms will implement mitigations. The likely responses: content validation on tenant name fields (pattern matching for phone numbers and financial language), rate limiting on backup email registration workflows, anomaly detection on new tenant provisioning, and enhanced abuse reporting infrastructure.

These mitigations will be effective against the specific documented technique. They will not be effective against the next technique, because the next technique will be designed around them. The structural challenge is that every platform feature that allows user-controlled text to flow into notification templates is a potential injection vector—and platforms have thousands of such features, only some of which have been examined for this attack surface.

The long-term platform response needs to be architectural: treating all user-controlled content in notification templates as untrusted, rendering it with appropriate context separation from template-controlled content, and implementing content-aware validation that applies consistent standards regardless of which specific field the content is sourced from.

15.4 The Regulatory and Legal Landscape

The regulatory response to trusted infrastructure phishing is nascent but developing. Key pressure points:

- **Cloud platform liability:** As LOTS attacks proliferate, regulatory frameworks may begin holding platforms to higher standards for abuse prevention—particularly when their own infrastructure is the delivery vehicle for fraud at scale. The EU's Digital Services Act (DSA) framework includes provisions for systemic risk assessment that could apply to this pattern.
 - **Incident reporting requirements:** SEC, CISA, and emerging EU NIS2 requirements mandate timely disclosure of material cybersecurity incidents. Trusted infrastructure phishing attacks that result in credential compromise or financial loss qualify; organizations need IR playbooks that include regulatory notification timelines.
 - **Insurance implications:** Cyber insurance underwriters are increasingly scrutinizing email security posture. The ability to demonstrate behavioral AI-based detection—rather than reliance on perimeter controls that fail against trusted infrastructure attacks—will likely become a premium determination factor.
-

16. Broader Cybersecurity Paradigm Shift

16.1 The End of the Perimeter Assumption

The Microsoft notification abuse attack is a data point in a larger paradigm shift: the complete obsolescence of the perimeter security model. Perimeter security assumed a clean boundary between "inside" (trusted) and "outside" (untrusted). The cloud era dissolved that boundary at the network level; LOTS attacks dissolve it at the application and identity level.

When the most trusted sender in the organization's email allowlist—Microsoft—can be co-opted to deliver malicious content, the "inside vs. outside" framework has no remaining operational meaning. The attack originates from inside Microsoft's infrastructure, passes through the organization's defended perimeter with its blessing, and lands in the victim's inbox as a trusted communication. There is no perimeter that could have stopped it.

The necessary paradigm shift is from **boundary-based trust** to **content-and-behavior-based trust evaluation**. Every message, regardless of its origin, should be evaluated against the question: "Is this content consistent with what I expect from this sender, given what I know about this sender's communication patterns, this user's context, and the organizational norm?" That evaluation requires behavioral AI, not rule books.

16.2 Identity as the New Perimeter—and Its Limitations

The security community's response to perimeter dissolution has been the "identity is the new perimeter" framework—the proposition that strong identity verification (phishing-resistant MFA, Zero Trust conditional access, privileged access management) is the foundational security control in a cloudified enterprise.

This framework is correct as far as it goes. But trusted infrastructure phishing reveals its limits. The Microsoft notification abuse attack doesn't compromise identity in the traditional sense—it doesn't steal a password or bypass MFA. It exploits the *trust humans place in verified identities* to deliver social engineering. The attack succeeds not because identity controls failed, but because the human who received an email from a verified Microsoft identity was manipulated by the content of that communication.

The "identity is the new perimeter" framework addresses the machine-to-machine trust layer. It does not address the human-to-machine trust layer—the moment when a human reads a notification from a verified sender and decides what to do about it. That layer requires a different defense: education, behavioral detection, and friction in high-risk human decisions.

16.3 The Thesis Restated: Authenticity ≠ Legitimacy

Throughout this paper, one proposition has recurred in different forms across every attack technique examined:

Authenticity no longer guarantees legitimacy.

This is not a statement about cryptography or authentication technology. Those systems work as designed. It is a statement about the *assumption* those systems were built to support—that verifying the origin of a communication tells you something meaningful about the trustworthiness of its content.

In the original email security threat model, that assumption held. Forged sender addresses were the primary threat; verifying the sender was the primary defense. In the current threat model, sophisticated adversaries have learned to *satisfy* authentication requirements while *corrupting* content—through platform feature abuse, through legitimate infrastructure co-option, through consent-based access that bypasses authentication controls entirely.

The authentication assumption needs to be retired as a foundation for trust decisions—not because authentication is useless (it still provides valuable signal), but because it is insufficient as the *primary* basis for trust. The question "is this message authentically from who it claims to be from?" must be supplemented by "is the content of this message consistent with what this sender legitimately does?"

That second question is behavioral. It is contextual. It requires memory of past interactions, understanding of normal patterns, and sensitivity to anomalous combinations. It is exactly the question that behavioral AI is designed to answer—and exactly the question that rule-based security systems, static allowlists, and authentication-based trust models are architecturally incapable of asking.

17. Conclusion

17.1 What the Campaign Reveals

The Microsoft notification abuse attack, as documented by Abnormal AI, is a small campaign in absolute terms—2,000 messages, 250 tenants, consumer-grade fraud as the immediate objective. It is a large campaign in what it reveals: the structural vulnerability of an enterprise security architecture built on authentication as the primary trust signal.

The attack worked because every layer of the conventional defense stack made the same implicit assumption—that an email genuinely sent from Microsoft's infrastructure, authenticated by Microsoft's certificates, delivered to an inbox through Microsoft's servers, is a legitimate communication. Each layer then built on that assumption rather than independently evaluating the communication's content for legitimacy.

The attacker's insight was to find a single point where attacker-controlled data entered Microsoft's legitimate communication pipeline—the Tenant Name field—and exploit the fact that no layer of the defense stack evaluated that specific input against a legitimacy standard. The authentication systems authenticated it. The allowlists passed it. The security gateways examined it and found nothing conventionally malicious. The user received what appeared to be an alarming but credible Microsoft security communication and responded accordingly.

17.2 What Must Change

Three things must change in response to this threat class, at three different levels:

At the platform level: Cloud platforms must treat user-controlled content in notification templates as untrusted input that requires content validation before being rendered in outbound communications. The assumption that a tenant administrator who accepted terms of service is a legitimate actor must give way to behavioral validation of how platform features are actually used.

At the enterprise security level: Behavioral AI-based email and identity security must replace—or meaningfully supplement—rule-based, authentication-anchored detection as the primary defense against sophisticated social engineering. The behavioral question ("is this consistent with normal?") must supplement the authentication question ("is this genuine?") in every trust evaluation.

At the human level: Security awareness programs must be updated to reflect the current threat model. The core training message needs to evolve from "don't click unexpected links" to "authentication does not imply legitimacy—verify the *content* of unexpected communications through independent channels, regardless of how genuine the sender appears."

17.3 The Long View

Trusted infrastructure phishing is not a temporary aberration that will be patched and resolved. It is the predictable endpoint of a trajectory: as perimeter defenses hardened, attackers moved to social engineering; as anti-spoofing improved, attackers moved to platform co-option; as link-based attacks became recognizable, attackers moved to callback delivery. Each shift preserved the core social engineering objective while adapting the delivery mechanism to circumvent the current defensive frontier.

The next shift is already in progress: AI-powered personalization of trusted infrastructure attacks, AI-operated vishing, and expansion of the LOTS technique to platforms and notification vectors that have not yet been discovered and documented. The defensive community's response must be equally adaptive—not writing rules that catch yesterday's campaign, but building detection architectures that evaluate tomorrow's variants against behavioral baselines that don't depend on knowing the specific technique in advance.

Authenticity is no longer legitimacy. The security industry's task is to build trust models that work in a world where that statement is operationally true.

End of Main Paper Body

Appendix A: Glossary of Terms

Term	Definition
Authenticity	The property of a communication genuinely originating from the claimed source, as verified by authentication mechanisms. Distinguished from legitimacy.
Behavioral AI	Machine learning systems that establish baselines of normal behavior and flag statistical anomalies, rather than matching against known threat signatures.
BazaCall / BazarCall	A callback phishing campaign (2020-2021) that pioneered the TOAD technique as an initial access vector for Conti and Ryuk ransomware.
Burn-and-churn	An operational model where attackers use infrastructure for brief periods then abandon it, preventing blocklist-based defenses from accumulating effective blocks.
Callback Phishing	See TOAD. An attack where the email payload is a phone number rather than a link; social engineering occurs via voice call.
Cognitive Tunneling	A psychological state induced by urgency where the brain narrows focus to resolving an immediate perceived threat, suppressing broader critical evaluation.
Consent Phishing	Phishing attacks that trick users into granting OAuth permissions to malicious applications, providing persistent access without credential theft.
DKIM	DomainKeys Identified Mail. Cryptographic email signing that proves message integrity and authenticates the signing organization's domain.

Term	Definition
DMARC	Domain-based Message Authentication, Reporting & Conformance. Policy framework requiring SPF or DKIM alignment with the visible From: domain.
Entra ID	Microsoft's cloud identity and access management platform (formerly Azure Active Directory). Manages authentication for Microsoft 365 tenants.
Homoglyph	A character that looks visually identical or nearly identical to another character but has a different Unicode codepoint. Used in obfuscation attacks.
Illicit Consent Grant	An OAuth attack where users are tricked into authorizing malicious applications, providing persistent access that survives password resets.
IOC	Indicator of Compromise. A forensic artifact indicating a security incident, such as a malicious IP, hash, or domain.
Legitimacy	The property of a communication serving its claimed legitimate purpose. An authenticated message can be authentic but not legitimate.
LOTS	Living off Trusted Sites. Attack technique that uses legitimate, high-reputation platforms to host or deliver malicious content, inheriting platform trust.
LotL	Living off the Land. Endpoint attack technique using native OS tools to avoid deploying custom malware. LOTS is the web/cloud equivalent.
MFA Fatigue	An attack where repeated MFA push notifications exhaust or confuse users into approving an unauthorized login. Also

Term	Definition
	called push bombing.
New-MgUserAuthenticationMethod	Microsoft Graph PowerShell SDK cmdlet for programmatically configuring user authentication methods, used by attackers to automate victim targeting.
Ogonek	A diacritical mark (a small hook) from Polish and Lithuanian scripts, attached to vowels (e.g., ą, ė). Used in Unicode obfuscation to defeat keyword filters.
OTP	One-Time Passcode. A time-limited code sent for identity verification. Microsoft sends OTPs when backup email addresses are registered.
PhaaS	Phishing-as-a-Service. Turnkey phishing kits and infrastructure available as subscription services in the cybercriminal ecosystem.
Polymorphic Campaign	An attack campaign where each message variant is semantically equivalent but syntactically distinct, defeating signature-based detection.
SEG	Secure Email Gateway. Inline email security proxy that inspects messages using signatures, URL reputation, sandboxing, and rule-based filters.
SPF	Sender Policy Framework. DNS-based mechanism allowing domain owners to publish lists of authorized sending IP addresses.
SSPM	SaaS Security Posture Management. Tools for continuously monitoring connected SaaS applications, OAuth grants, and configurations.

Term	Definition
System Notification Abuse	Attacks that inject malicious content into legitimate platform notification templates, forcing the platform to deliver the payload through its own infrastructure.
Tenant	In Microsoft 365 / Entra ID, an isolated cloud environment representing a single organization. Attackers provision disposable tenants for LOTS attacks.
TOAD	Telephone-Oriented Attack Delivery. Phishing attacks where the payload is delivered via a callback phone number rather than a link or attachment.
Trusted Infrastructure Phishing	The broader attack category encompassing attacks that co-opt legitimate platform infrastructure to deliver malicious content.
VENOM	A PhaaS platform identified by Abnormal AI targeting C-suite executives, hijacking Microsoft sign-ins and OAuth tokens.
Vishing	Voice phishing. Social engineering attacks conducted via telephone call. Used in the callback phase of TOAD attacks.

Appendix B: Attack Flow Diagram

ATTACKER OPERATIONS

- ```
[1] Register Microsoft 365 free trial tenant
 ↳ Subdomain: Williford316.onmicrosoft.com

[2] Set Tenant Name = "Your Bitcoin Purchased of
 USD 498.95 Completed through PayPal.
 Reach Support Desk at 802 538 3069 to CanceI"
 (with Unicode obfuscation + digit-to-letter encoding)

[3] Create user accounts within tenant
 (automated via New-MgUserAuthenticationMethod)

[4] For each target email in target list:
 Navigate to mysignins.microsoft.com/security-info
 → Add sign-in method → Email
 → Enter VICTIM email address
```



## MICROSOFT INFRASTRUCTURE (Legitimate)

```
Microsoft security logic triggers:
Generate OTP → Construct notification email

Subject: {Tenant Name} + "account email verification code"
= "Your Bitcoin Purchased... CanceI account email
 verification code"

Sender: msonlineservicesteam@microsoftonline.com
SPF: PASS | DKIM: PASS | DMARC: PASS
URLs: privacy.microsoft.com, www.microsoft.com (only)
```

▼

## VICTIM ORGANIZATION DEFENSES

| SEG checks: SPF PASS → allowlisted sender → bypass |  
| No malicious URLs: PASS |  
| No malicious attachments: PASS |  
| Keyword rules: BYPASSED (Unicode obfuscation) |  
| Phone number regex: BYPASSED (digit-to-letter encoding) |  
| Email delivered to inbox ✓ |

|

▼

## VICTIM HUMAN INTERACTION

| Victim reads email → sees "Bitcoin charge" + OTP code |  
| Cognitive triggers: URGENCY + AUTHORITY + DISSONANCE |  
| Victim calls callback number |  
|  
| Vishing operator answers: |  
| → Request payment credentials / remote access / PII |  
|  
| Attacker abandons tenant (burn-and-churn) |

## Appendix C: MITRE ATT&CK Mapping (Extended)

---

| ATT&CK ID | Technique                             | Sub-technique                                 | Campaign Application                                      |
|-----------|---------------------------------------|-----------------------------------------------|-----------------------------------------------------------|
| T1566     | Phishing                              | T1566.002 – Spearphishing Link                | Notification delivery triggering callback                 |
| T1078     | Valid Accounts                        | T1078.004 – Cloud Accounts                    | Disposable tenant accounts as delivery mechanism          |
| T1036     | Masquerading                          | T1036.005 – Match Legitimate Name or Location | Tenant name mimics legitimate security communications     |
| T1585     | Establish Accounts                    | T1585.001 – Social Media Accounts             | Disposable M365 tenant/account provisioning at scale      |
| T1656     | Impersonation                         | —                                             | Vishing operator poses as Microsoft/bank support          |
| T1598     | Phishing for Information              | T1598.003 – Spearphishing via Service         | Callback designed to harvest credentials and payment data |
| T1059     | Command and Scripting Interpreter     | T1059.001 – PowerShell                        | Graph PowerShell SDK for automated provisioning           |
| T1027     | Obfuscated Files or Information       | T1027.010 – Command Obfuscation               | Unicode ogonek substitution, digit-to-letter encoding     |
| T1550     | Use Alternate Authentication Material | T1550.001 – Application Access Token          | OAuth token harvesting in related PhaaS campaigns         |

| ATT&CK ID | Technique                                | Sub-technique               | Campaign Application                                       |
|-----------|------------------------------------------|-----------------------------|------------------------------------------------------------|
| T1111     | Multi-Factor Authentication Interception | —                           | OTP interception via callback (related variant)            |
| T1204     | User Execution                           | T1204.001 – Malicious Link  | Victim initiating callback (human execution phase)         |
| T1090     | Proxy                                    | T1090.004 – Domain Fronting | Disposable<br>onmicrosoft.com<br>subdomains masking origin |

**ATT&CK Tactics Traversed:** - **Initial Access** (TA0001): T1566 – Phishing - **Resource Development** (TA0042): T1585, T1586, T1587 - **Execution** (TA0002): T1204 – User Execution (callback) - **Defense Evasion** (TA0005): T1036, T1027, T1078 - **Credential Access** (TA0006): T1598, T1111 - **Collection** (TA0009): T1114 – Email Collection (via OAuth variants)

---

## Appendix D: Related Incidents and Comparable Campaigns

---

| Campaign / Incident                             | Date         | Technique                                                                 | Platform         | Outcome                                           |
|-------------------------------------------------|--------------|---------------------------------------------------------------------------|------------------|---------------------------------------------------|
| <b>BazaCall / BazarCall</b>                     | 2020–2021    | Callback phishing via fake subscription emails                            | Email            | Initial access for Conti/Ryuk ransomware          |
| <b>Storm-1811 Teams Attacks</b>                 | 2024         | External Teams tenant impersonation + QuickAssist                         | Microsoft Teams  | Remote access, credential theft                   |
| <b>VENOM PhaaS</b>                              | 2025–2026    | C-suite OAuth token hijacking via live sign-in interception               | Microsoft 365    | Persistent OAuth access to executive accounts     |
| <b>Google Drive Share Notification Phishing</b> | 2022–ongoing | Malicious Drive document shared to trigger legitimate Google notification | Google Workspace | Credential harvesting, malware delivery           |
| <b>DocuSign Notification Abuse</b>              | 2023–ongoing | Fraudulent DocuSign envelopes from legitimate accounts                    | DocuSign         | Credential harvesting via legitimate signing flow |
| <b>Canva Phishing Campaigns</b>                 | 2023–ongoing | Phishing pages hosted on Canva, delivered via Canva notifications         | Canva            | Credential harvesting, redirect to phishing pages |
| <b>GitHub Gist C2</b>                           | 2022–ongoing | GitHub Gist used as command-and-control interface                         | GitHub           | Persistent C2 blending with developer traffic     |



| Campaign / Incident            | Date      | Technique                                                         | Platform           | Outcome                                 |
|--------------------------------|-----------|-------------------------------------------------------------------|--------------------|-----------------------------------------|
| Microsoft Device Code Phishing | 2024–2025 | Legitimate device code authentication flow abused for token theft | Microsoft Entra ID | Persistent token access without MFA     |
| ScreenConnect Abuse Campaign   | 2024      | Legitimate remote management tool abused post-callback            | Multiple           | Remote access for ransomware deployment |

## Appendix E: References and Source Links

---

### Primary Source

1. Aaron Orchard, Abnormal AI. "System Notification Abuse: How Attackers Force Microsoft to Send Phishing Emails." January 29, 2026. <https://abnormal.ai/blog/system-notification-abuse-microsoft-phishing>

### Microsoft Documentation and Security Research

1. Microsoft Security Response Center. "Protect Against Consent Phishing." Microsoft Learn. <https://learn.microsoft.com/en-us/microsoft-365/security/>
2. Microsoft Threat Intelligence. "Midnight Blizzard conducts targeted social engineering over Microsoft Teams." Microsoft Security Blog, 2023.
3. Microsoft. "Configure Microsoft Authenticator authentication methods." Entra ID documentation.
4. Microsoft. "Number matching in Microsoft Authenticator." Entra ID MFA documentation.

### MITRE ATT&CK Framework

1. MITRE Corporation. ATT&CK Enterprise Matrix v16. <https://attack.mitre.org/>
2. MITRE. T1566 – Phishing. <https://attack.mitre.org/techniques/T1566/>
3. MITRE. T1078.004 – Valid Accounts: Cloud Accounts. <https://attack.mitre.org/techniques/T1078/004/>

### Email Authentication Standards

1. Kitterman, S. RFC 7208 – Sender Policy Framework (SPF). IETF.
2. Crocker, D., et al. RFC 6376 – DomainKeys Identified Mail (DKIM). IETF.
3. Kucherawy, M., Zwicky, E. RFC 7489 – Domain-based Message Authentication, Reporting, and Conformance (DMARC). IETF.

### Threat Intelligence and Security Research

1. Abnormal AI Threat Intelligence. "VENOM PhaaS: C-Suite Microsoft Credential Theft Report." 2026. <https://abnormal.ai/resources/venom-phaas-c-suite-microsoft-credential-theft-report>
2. Proofpoint. "State of the Phish 2024." Annual threat report.
3. CrowdStrike. "2024 Global Threat Report." CrowdStrike Intelligence.
4. Sekoia.io. "BazaCall Analysis." Threat Intelligence Report.
5. HHS Cybersecurity Program. "BazaCall Telephone-Oriented Attack Delivery." HC3 Analyst Note.

6. Hunters Security. "Microsoft Teams External Tenant Phishing Analysis." 2024.
7. Elastic Security Labs. "Abusing legitimate Microsoft applications for initial access." 2024.

## Psychology of Social Engineering

1. Cialdini, R.B. *Influence: The Psychology of Persuasion*. Harper Business, 2006. (Foundation framework for authority, urgency, scarcity triggers documented in Section 7.)
2. Vishwanath, A. "Habitual Facebook Use and Its Impact on Getting Deceived on Social Media." *Journal of Computer-Mediated Communication*, 2015.

## AI and Phishing

1. CrowdStrike. "Generative AI and the Future of Phishing." *Intelligence Brief*, 2024.
2. Knowbe4 Research. "The AI-Powered Phishing Report." 2024.

## Living off Trusted Sites

1. Spamhaus. "Living off Trusted Sites (LOTS) – An Analysis." *Threat Research*, 2023–2024.
2. Zscaler ThreatLabz. "Phishing Report 2024: SaaS Platform Abuse Trends."
3. Check Point Research. "The Trusted Platform Phishing Problem." *Security Blog*, 2024.

---

### Document Information

*Title: Authenticity Is Not Legitimacy: The Rise of Trusted Infrastructure Phishing*

*Version: 1.0*

*Date: May 26 2026*

*Classification: Public Research — For Distribution*

*Word Count: ~18,000 words*

*Sections: 17 + 5 Appendices*

*This paper was produced through primary source analysis, multi-source research validation, and synthesis of publicly available threat intelligence. Technical claims are sourced and confidence-leveled throughout. Speculative or forward-looking statements are clearly framed as forecasts or analytical opinions rather than established fact.*

---

*End of Document*